

GUÍA 01 · MAPA DEL SISTEMA

Flujo y funcionamiento

Qué ocurre desde que entra un correo hasta que se explica el riesgo

Proyecto TFG · versión alineada con el código actual

Alejandro Villarrubia García

Universidad Europea Miguel de Cervantes

Índice

1. Idea general	2
2. Flujo completo	2
3. Piezas y responsabilidades	2
4. Cómo se analiza un EML	3
5. Monitor y persistencia	3
6. API y extensión	3
7. Ejemplo de extremo a extremo	4
8. Límites que conviene decir	4

1. Idea general

El montaje es cliente-servidor. El navegador usa Streamlit como capa de presentación y Streamlit envía peticiones HTTP/JSON al backend central. La extensión y el monitor también consumen esa API. Solo el servidor parsea, analiza, entrena y guarda los modelos; Gmail y Telegram son integraciones externas. La web comparte una interfaz adaptable con navegación de marca, estados homogéneos y un flujo de detección ordenado en tres pasos.

Nota para la defensa

Frase para la defensa: Aunque cliente y servidor estén en el mismo ordenador, son procesos separados con un contrato HTTP y comparten una versión activa por idioma. Para la demo móvil, mantén el backend en 127.0.0.1:8766 e inicia Streamlit con `–server.address 0.0.0.0 –server.port 8501`; el móvil usa la IP privada. Es acceso temporal a una LAN de confianza, no Internet, y la web no tiene autenticación multiusuario.

2. Flujo completo

1. Entrada de cliente: la web, la extensión o el monitor envían texto, campos JSON o un EML Base64 al backend; `/analyze` limita la petición a 16 MiB.
2. Normalización: se extraen remitente, asunto, cuerpo, HTML, cabeceras completas, URLs, anclas y adjuntos.
3. Señales: se revisan autenticación, coherencia de dominios, URLs, punycode, acortadores, HTML, formularios, lenguaje urgente y adjuntos.
4. Puntuación heurística: RiskScorer pondera las señales activas y produce un riesgo de 0 a 100; ExplanationBuilder conserva el motivo.
5. Idioma y modelo: EmailAnalysisService detecta español o inglés por mensaje y reutiliza un detector neuronal cacheado por idioma.
6. Decisión: el modo combinado calcula la media 45/55 y conserva el máximo de ambos detectores si alcanza 70. El umbral común de 21 determina el veredicto en los tres modos.
7. Salida: el backend devuelve clasificación, puntuación, explicación, señales, idioma y versión; el cliente se limita a presentarlos o generar la alerta.

3. Piezas y responsabilidades

Cuadro 1: Piezas y responsabilidades

Capa	Módulo	Responsabilidad	Resultado
Entrada	analizador_email.py	Parseo MIME seguro y extracción de partes	Correo normalizado
Dominio	correo.py	Contrato común para texto, diccionario o EML	CorreoAnalizado
Señales	header_signals, url_utils, html_signals, content_signals	Reglas pequeñas y comprobables	Diccionario de señales

Capa	Módulo	Responsabilidad	Resultado
Cliente	backend_client.py	Contrato HTTP común sin lógica de detección	Petición/respuesta JSON
Servidor	backend_service.py	Casos de uso, idioma, versiones y administración	Resultado central
ML	modelo_neural.py	TF-IDF, MLP, entrenamiento y persistencia del servidor	Puntuación de clase positiva
Presentación	Streamlit, monitor, extensión	Recoger entrada y mostrar o alertar	UI o alerta

4. Cómo se analiza un EML

El parser usa `email.parser.BytesParser` con una política MIME estándar. Conserva todas las cabeceras repetidas, no solo la última, y serializa las cabeceras originales junto al cuerpo. SPF, DKIM y DMARC se interpretan únicamente desde `Received-SPF`, `Authentication-Results`, `ARC-Authentication-Results` y `DKIM-Signature`: el prototipo no consulta DNS, no recupera claves públicas y no realiza una validación criptográfica completa.

- Texto plano: se decodifica respetando el charset declarado y se conserva como cuerpo analizable.
- HTML: se guarda separado para revisar formularios, meta refresh, iframes, base href y javascript/data URLs.
- Adjuntos: se anotan nombre y tipo sin ejecutar ni abrir contenido potencialmente peligroso.
- URLs: se deduplican, se limpian de puntuación y se extraen también de enlaces HTML.

5. Monitor y persistencia

El monitor consulta Gmail, carga los IDs vistos y procesa solo mensajes nuevos. Cada correo normalizado se envía al backend con `RemoteAnalysisService`; el monitor no carga modelos. El estado se escribe después de cada mensaje completado mediante fichero temporal y `os.replace`.

Si un EML está corrupto o falla una alerta de Telegram, ese mensaje queda reportado con error y el resto del lote continúa. Un fallo de entrada no se convierte en una caída global del proceso.

6. API y extensión

Cuadro 2: Endpoints y controles de la API

Endpoint	Entrada	Respuesta	Controles
GET /health y /models	Sin cuerpo	Estado y versiones sin rutas locales	No-store; sin artefactos
POST /analyze	JSON hasta 16 MiB	Riesgo, explicación, idioma y versión	Tipos, tamaño y CORS
POST /train y /evaluate	CSV serializado hasta 256 MiB	Versión y métricas	Token admin opcional en local

Endpoint	Entrada	Respuesta	Controles
POST / compare y / models/delete	Configuraciones o idioma	Comparación o confirmación	Token y límites

La extensión de Gmail no ejecuta Python: recoge el correo visible y lo envía directamente al backend central, por defecto en 127.0.0.1:8766. El proceso del puerto 8767 se conserva únicamente como proxy de compatibilidad y tampoco carga modelos.

7. Ejemplo de extremo a extremo

1. El usuario abre un correo con asunto urgente y un enlace que aparenta ser de una marca conocida.
2. El adaptador extrae From, Subject, cuerpo, anclas y URL.
3. Las reglas detectan urgencia, dominio externo, anchor distinto y posible incoherencia de cabeceras.
4. El modelo neuronal calcula una puntuación de clase positiva sobre el texto normalizado. Su significado depende de las etiquetas del corpus: spam/ham en ES y mezcla spam/phishing en EN.
5. El modo combinado aplica la fusión calibrada 45/55 y el umbral 21; si una evidencia alcanza 70 no se diluye, y la explicación muestra qué señales activaron el riesgo.
6. La UI pinta la tarjeta, la extensión la inserta en Gmail y el monitor podría notificar por Telegram.

8. Límites que conviene decir

- La lista de dominios y señales es local; no se afirma que exista reputación online en tiempo real.

Los pesos 45/55 dependen de los modelos y de los 40 casos de calibración. En los 16 EML finales, el heurístico acierta 16 y el combinado 14; combinar no mejora esta prueba ni garantiza un resultado superior con otros datos.

- El análisis apoya decisiones y las 94 pruebas más 2 recorridos validan el flujo, no la eficacia en producción; el MLP requiere datos representativos y evaluación separada.